

MICROSOFT 365 · ADMINISTRACIÓN

Roles, permisos y privilegios

Administración delegada · Grupos de roles · Unidades administrativas · Permisos de SharePoint · Privileged Identity Management

Resumen del módulo

Contenido del módulo

- | | | |
|-----------|---|--|
| 01 | Administración delegada a partners | Autorización, roles Full y Limited y buenas prácticas de delegación. |
| 02 | Grupos de roles | Asignación de roles a grupos, protección y requisitos de licencia. |
| 03 | Unidades administrativas | Alcance de permisos por división, geografía o suborganización. |
| 04 | Permisos de SharePoint | Prevención del uso compartido excesivo de datos (oversharing). |
| 05 | Privileged Identity Management | Acceso just-in-time y elevación controlada de privilegios. |

01

Delegar la administración a partners

Administración delegada, roles asignados por el partner y buenas prácticas

Administración delegada

Una organización sin administradores internos puede externalizar la administración de Microsoft 365 a un partner de Microsoft. El partner inicia el proceso enviando un correo para solicitar permiso para actuar como administrador en su nombre.

Aceptar la oferta del partner

- 1 Abrir el correo del partner y revisar los términos.
- 2 Seleccionar el enlace para autorizar el acuerdo.
- 3 En Delegated administration, seleccionar Yes.
- 4 Crear la cuenta del tenant si la oferta incluye suscripción.

Consultar administradores delegados

- 1 Ir a Active users en el Centro de administración.
- 2 Seleccionar Filter.
- 3 Elegir cualquiera de los roles asignados en la lista.

Si no hay ninguno: "There are no delegated administrators associated with your account."

Roles de administración establecidos por partners

El partner puede asignar roles a agentes de soporte de su organización y a usuarios del cliente. Existen dos roles disponibles.

Full Administration

- Usuarios, cuentas, licencias, dominios y servicios.
- Creación de usuarios y asignación de roles y permisos.
- Configuraciones de seguridad, como políticas de contraseñas.
- Suscripciones: compra y asignación de licencias.
- Exchange Online, correo y buzones.
- Acceso a los datos de la organización.
- Sitios y archivos de SharePoint Online.

Limited Administration

- Crear y modificar cuentas de usuario.
- Restablecer contraseñas.
- Administrar membresías de grupos.
- Consultar estado del servicio y soporte.
- Ver y administrar tickets de soporte.
- No permite administrar dominios, suscripciones ni seguridad.

Buenas prácticas para la administración delegada

Evaluar cuidadosamente el nivel de confianza y acceso concedido al partner, y verificar que los roles se ajusten a los requisitos de seguridad y cumplimiento.

Planificar

- Diseñar una matriz que distribuya los roles según el modelo operativo de la organización.

Documentar

- Documentar y auditar los roles administrativos y los privilegios asociados.

Mantener

- Actualizar, modificar o eliminar los roles cuando cambien las necesidades.

Aprobar

- Obtener aprobación de la dirección para el diseño final de los roles.

Las capacidades y permisos pueden cambiar con el tiempo: consultar la documentación oficial de Microsoft o al partner para obtener información actualizada.

02 Implementar grupos de roles

Asignar roles a grupos, protegerlos y hacerlos elegibles mediante PIM

Ventajas de los grupos de roles

Los grupos de roles permiten asignar roles a un grupo en lugar de a usuarios individuales. Pueden incluir roles integrados de Microsoft 365 y roles personalizados de la organización.

Simplifican la asignación

- Un único grupo en lugar de múltiples asignaciones individuales, con permisos consistentes.

Seguridad y cumplimiento

- Facilitan el mínimo privilegio y la separación de funciones.

Productividad y colaboración

- Agrupan usuarios según sus roles y responsabilidades.

Administración sencilla

- Agregar o quitar miembros asigna o retira los roles indirectamente.

Buenas prácticas con grupos de roles

Usar grupos integrados

- Microsoft ofrece grupos predefinidos para escenarios habituales.
- Helpdesk Administrator.
- Service Support Administrator.
- Reports Reader.

Crear grupos personalizados

- Cuando los grupos integrados no cubren las necesidades.
- Aplicar el principio de mínimo privilegio.
- Mantener la separación de funciones.

Revisar y actualizar

- Ajustar roles y miembros ante cambios de requisitos.
- Considerar cambios de servicios y responsabilidades.
- Revisar cuando cambien los integrantes de la organización.

Crear grupos de roles personalizados

El grupo de seguridad o de Microsoft 365 debe ser role-assignable: la propiedad `isAssignableToRole` debe establecerse en `true`.

Microsoft 365 admin center

- 1 En un grupo de seguridad, marcar "Azure AD roles can be assigned to the group".
- 2 En un grupo de Microsoft 365, Privacy = Private y permitir roles de administrador.
- 3 Abrir el grupo ya creado y asignarle los roles.
- 4 Agregar los usuarios como miembros.

Microsoft Entra admin center

- 1 Establecer "Microsoft Entra roles can be assigned to the group" en Yes.
- 2 Asignar uno o más roles de Microsoft Entra durante la creación.
- 3 Agregar los usuarios como miembros del grupo.

Creación mediante Microsoft Graph PowerShell

- 1 Crear el grupo con `New-MgGroup` y `-IsAssignableToRole:$true`.
- 2 Obtener la definición del rol con `Get-MgRoleManagementDirectoryRoleDefinition`.
- 3 Asignar el rol al grupo con `New-MgRoleManagementDirectoryRoleAssignment`.

PowerShell

```
Connect-MgGraph -Scopes "Group.ReadWrite.All"
```

```
$group = New-MgGroup -SecurityEnabled -MailEnabled:$false  
-DisplayName "Contoso_Helpdesk_Administrators"  
-MailNickName "contosohelpdeskadministrators"  
-IsAssignableToRole:$true
```

```
$roleDefinition = Get-MgRoleManagementDirectoryRoleDefinition  
-Filter "displayName eq 'Helpdesk Administrator'"
```

```
$roleAssignment = New-MgRoleManagementDirectoryRoleAssignment  
-DirectoryScopeId '/' -PrincipalId $group.Id  
-RoleDefinitionId $roleDefinition.Id
```

Protección de los grupos de roles

Un administrador que pueda modificar la membresía podría agregarse a sí mismo y elevar sus privilegios. Por eso la membresía es de tipo Assigned y solo administradores autorizados, como los Global Administrators, pueden gestionarla.

RESTRICCIONES

- `isAssignableToRole` es inmutable tras la creación del grupo.
- Un grupo existente no puede convertirse en grupo de roles.
- Máximo de 500 grupos de roles por organización de Microsoft Entra.
- Solo Global Administrators y Privileged Role Administrators pueden crearlos; la administración puede delegarse a propietarios.
- La membresía debe ser Assigned: no se admiten grupos dinámicos.
- Microsoft Graph requiere `RoleManagement.ReadWrite.Directory`; `Group.ReadWrite.All` no basta.
- Solo Privileged Authentication Administrator o Global Administrator puede cambiar credenciales, MFA o atributos sensibles.
- No se admite el anidamiento de grupos.

Elegibilidad mediante PIM y licencias

Hacer un grupo elegible con PIM

- Evita que los miembros tengan acceso permanente a un rol.
- Cada miembro activa la asignación durante un período determinado.
- Para elevar privilegios en roles de Microsoft Entra, Microsoft recomienda exigir un proceso de aprobación.
- Las asignaciones activables sin aprobación pueden suponer un riesgo de seguridad con administradores menos privilegiados.

Requisitos de licencia

Microsoft Entra ID P1

Necesario para utilizar grupos de roles.

Microsoft Entra ID P2

Necesario para usar PIM y la activación de roles just-in-time.

03

Unidades administrativas en Microsoft Entra ID

Limitar el alcance de los permisos a una parte concreta de la organización

Qué es una unidad administrativa

Recurso de Microsoft Entra que funciona como contenedor de usuarios, grupos o dispositivos y permite limitar el alcance de los permisos de un rol a una parte específica de la organización. Un usuario puede pertenecer a varias unidades, por ejemplo una por geografía y otra por división.

Ejemplo de delegación

- Delegar el rol Helpdesk Administrator a especialistas regionales.
- Cada especialista administra únicamente los usuarios de su región.
- Útil en organizaciones con divisiones independientes.

Escenario: universidad

- 1 Crear una unidad para la School of Business.
- 2 Agregar únicamente sus estudiantes y personal.
- 3 Crear un rol con permisos limitados a esa unidad.
- 4 Asignar el equipo de TI de la escuela a ese rol.

Licencias, herramientas y estructura

Requisitos de licencia

- Cada administrador de una unidad: Microsoft Entra Premium P1.
- Cada miembro de una unidad: Microsoft Entra Free.
- Con reglas de membresía dinámica: Premium P1 por miembro.

Herramientas de administración

- Microsoft Entra admin center.
- PowerShell.
- Microsoft Graph API.

Estructuras representables

- Límites geográficos de la organización.
- Suborganizaciones semiautónomas.
- Divisiones organizativas.
- La estructura se define según las necesidades y el uso previsto en los servicios de Microsoft 365.

Ciclo de adopción y escenarios compatibles

CICLO DE ADOPCIÓN

1

Adopción inicial

Se crean unidades según los criterios iniciales; su número puede crecer mientras se refinan.

2

Poda (pruning)

Se eliminan las unidades que ya no son necesarias.

3

Estabilización

Definida la estructura, el número de unidades no cambia significativamente.

ESCENARIOS COMPATIBLES

Como Global o Privileged Role Administrator

- Crear unidades administrativas.
- Agregar usuarios, grupos o dispositivos.
- Administrar usuarios o dispositivos mediante reglas de membresía dinámica.
- Asignar personal de TI a roles con alcance sobre unidades administrativas.
- Los administradores con alcance pueden hacer administración básica de usuarios desde el Centro de administración de Microsoft 365.

Alcance real de las unidades administrativas

- Las unidades limitan únicamente los permisos de administración.
- No impiden que usuarios o administradores usen sus permisos predeterminados para consultar otros usuarios, grupos o recursos fuera de la unidad.
- El Centro de administración de Microsoft 365 puede filtrar los usuarios visibles para un administrador con alcance...
- ...pero ese administrador puede consultar otros usuarios desde Microsoft Entra admin center, PowerShell y otros servicios.
- No hay funciones a nivel de organización para un rol con alcance de unidad: solo se admiten las funcionalidades indicadas.

Restricciones

- Las unidades administrativas no pueden anidarse.
- Los administradores de cuentas con alcance de unidad no pueden crear ni eliminar usuarios.
- Una asignación con alcance no alcanza a los miembros de un grupo agregado, salvo que se agreguen directamente a la unidad.
- Actualmente no están incluidas en Microsoft Entra Identity Governance.

Administración de unidades administrativas

Operación	Graph / PowerShell	Entra admin center	M365 admin center
Crear o eliminar unidades administrativas	✓	✓	
Agregar o quitar miembros individualmente	✓	✓	
Agregar o quitar miembros mediante archivos CSV		✓	No previsto
Asignar administradores con alcance de unidad	✓	✓	
Agregar o quitar usuarios o dispositivos con reglas (preview)	✓	✓	
Agregar o quitar grupos dinámicamente mediante reglas			

Administración de usuarios y grupos con alcance

USUARIOS

Operación	Graph / PS	Entra	M365
Propiedades y contraseñas	✓	✓	✓
Licencias de usuarios	✓		✓
Bloquear o desbloquear inicios de sesión	✓	✓	✓
Credenciales de MFA	✓	✓	

GRUPOS

Operación	Graph / PS	Entra	M365
Propiedades y membresía de grupos	✓	✓	
Licencias de grupos	✓	✓	

Dispositivos y administración de permisos

DISPOSITIVOS

Operación	Graph / PS	Entra	M365
Habilitar, deshabilitar o eliminar dispositivos	✓	✓	
Leer claves de recuperación de BitLocker	✓	✓	

Roles personalizados con alcance

- Se pueden crear roles personalizados limitados a una unidad concreta.
- No existe un rol con alcance global sobre todas las unidades.
- Alternativa: crear un rol personalizado y asignarlo individualmente en cada unidad.

Grupos dentro de una unidad

- Agregar un grupo afecta al grupo en sí, no a sus miembros.
- Se debe al modelo RBAC de Microsoft Entra ID.
- Para administrar métodos de autenticación de esos usuarios, hay que agregarlos directamente a la unidad.

04

Permisos de SharePoint y oversharing

Evitar que el contenido quede accesible para una audiencia más amplia de la prevista

Qué es el oversharing

El oversharing ocurre cuando contenido de SharePoint queda accesible para una audiencia más amplia de la prevista.

Causas habituales

- Guardar archivos críticos en ubicaciones accesibles para demasiadas personas, incluidos externos.
- Compartir con grupos grandes en lugar de personas específicas.
- No revisar los permisos al cargar archivos.

Por qué importa

- SharePoint y Microsoft Copilot usan los datos sobre los que el usuario tiene al menos permisos de View.
- El contenido ampliamente compartido puede aparecer ante usuarios que ignoran que tienen acceso.
- Riesgo de exponer información sensible a destinatarios no previstos.

Los administradores deben usar el modelo de permisos de SharePoint para que usuarios y grupos accedan únicamente al contenido que les corresponde. Algunas funcionalidades requieren licencia de SharePoint Advanced Management.

Paso 1 · Revisar los controles de uso compartido

El People Picker permite buscar y seleccionar usuarios, grupos y claims al asignar permisos. Su opción Everyone Except External Users incluye a todos los usuarios internos y excluye a los externos, lo que puede provocar oversharing con una audiencia interna demasiado amplia.

- Revisar los controles de uso compartido a nivel de sitio y deshabilitar Everyone Except External Users; los usuarios pueden seguir compartiendo con personas o grupos concretos.
- Promover el uso cuidadoso de permisos a nivel de sitio, biblioteca y carpeta, y educar sobre los riesgos del oversharing.
- Formar a los administradores de sitios en los controles disponibles para restringir el uso compartido.
- Configurar a los Site Owners como destinatarios de las solicitudes de acceso.
- Ocultar del People Picker los permisos de alcance amplio para evitar su uso accidental.
- Cambiar los vínculos predeterminados de toda la organización a vínculos para personas específicas.

Pasos 2 y 3 · Identificar riesgos

Paso 2 · Sitios inactivos

- Identificar sitios inactivos durante mucho tiempo para reducir la superficie de contenido potencialmente sobrecompartido.
- Utilizar las Inactive Site Policies de SharePoint Advanced Management.
- Restringir permisos mediante Restricted Access Control.
- Eliminar los sitios cuando corresponda.

Paso 3 · Contenido sobrecompartido

- Usar los informes del Centro de administración de SharePoint para detectar uso compartido amplio.
- Los informes de Data Access Governance analizan los últimos 28 días:
- Uso de Everyone Except External Users.
- Vínculos People in your organization.
- Vínculos Anyone.
- Descargables en CSV; también se pueden crear informes personalizados con Microsoft Graph Data Connect for SharePoint.

Paso 4 • Aplicar acciones de corrección

Las acciones deben considerar la sensibilidad de los datos, la gravedad del oversharing y la necesidad de mantener las operaciones del negocio.

Acción inmediata

- Configurar una Restricted Access Control Policy para el sitio.
- El acceso existente queda restringido al grupo configurado y solo ese grupo ve el contenido.
- La política funciona tanto en OneDrive como en SharePoint.
- Usar Change History para determinar quién, cómo y cuándo provocó el oversharing.

Intervención de los propietarios

- Contactar a los propietarios de los sitios detectados en los informes de Data Access Governance.
- Informarles de los archivos o carpetas compartidos en exceso.
- Solicitar que eliminen manualmente los accesos innecesarios.
- Usar Site Access Review para que revisen el contenido, quiten permisos o justifiquen la necesidad.

Paso 5 · Proteger sitios críticos para el negocio

Los administradores de SharePoint deben aplicar Restricted Access Control de forma preventiva en los sitios críticos.

Restricted Access Control

- Aplicarlo preventivamente sobre los sitios críticos para el negocio.

Block download policy

- Impedir las descargas desde los sitios seleccionados.

Grabaciones de Teams

- Bloquear específicamente la descarga de grabaciones de reuniones.

Cifrado con extract rights

- Proteger los documentos de Office críticos para el negocio.

05

Privileged Identity Management

Elevar privilegios de forma controlada con acceso just-in-time

Beneficios de PIM

Microsoft Entra Privileged Identity Management permite administrar, controlar y supervisar el acceso de los usuarios a recursos de Microsoft Entra ID, Azure y otros servicios de Microsoft, como Microsoft 365 e Intune.

- Identifica a los usuarios con roles privilegiados o administrativos.
- Proporciona acceso administrativo just-in-time bajo demanda a:
 - Microsoft 365 e Intune, recursos de Azure, grupos de recursos y recursos individuales como máquinas virtuales.
- Mantiene un historial de activaciones administrativas y de los cambios realizados en recursos de Azure.
- Genera alertas ante cambios en las asignaciones administrativas.
- Puede requerir aprobación para activar roles administrativos privilegiados.
- Permite revisar la pertenencia a roles administrativos y exigir una justificación para mantenerla.

Acceso administrativo just-in-time

Modelo tradicional

- Un administrador asigna permanentemente el rol administrativo al usuario.
- Se realiza desde el Centro de administración de Microsoft Entra, otros portales o PowerShell.
- El usuario mantiene privilegios elevados de forma continua (standing admin access).

Administrador elegible con PIM

- El usuario es elegible para el rol, pero no lo tiene activo de forma permanente.
- Debe activar el rol cuando necesita realizar una tarea administrativa.
- La activación es temporal y dura un período predeterminado.
- Reduce o elimina el acceso administrativo permanente.

Privileged Role Administrator (PRA)

El PRA administra PIM y las asignaciones de roles privilegiados: determina qué usuarios necesitan privilegios elevados y les asigna los roles correspondientes.

Administrar roles privilegiados

- Definir qué roles requieren privilegios elevados y asignarlos según el negocio y el mínimo privilegio.

Gestionar el acceso JIT

- Configurar políticas de acceso temporal y revisar, aprobar o rechazar solicitudes.

Supervisar y auditar

- Revisar registros e informes para detectar actividad no autorizada y actuar cuando corresponda.

Seguridad y cumplimiento

- Alinear el acceso privilegiado con las políticas de seguridad y cumplimiento.

Documentación y capacitación

- Establecer pautas y materiales sobre el uso seguro de cuentas privilegiadas.

Roles disponibles en PIM

Roles integrados como Global Administrator, Exchange Administrator y SharePoint Administrator, además de roles personalizados.

Solicitar la activación de un rol

- Un usuario elegible debe activar el rol cuando necesite realizar acciones privilegiadas.
- En lugar de asignar permanentemente Global Administrator, se hace al usuario elegible para un rol como Exchange Online Administrator.
- Durante la activación, PIM agrega temporalmente una asignación activa al rol.
- Al desactivarse manualmente o al finalizar el período, PIM elimina esa asignación activa.
- La propagación del cambio puede depender de la arquitectura y la caché de cada aplicación.

Recomendación

Solicitar el menor alcance de recursos necesario y utilizar la activación temporal para reducir la exposición de los privilegios elevados, aplicando el principio de mínimo privilegio.

Proceso de activación de un rol

- 1 Iniciar sesión en Microsoft Entra admin center.
- 2 Acceder a Privileged Identity Management desde Identity governance.
- 3 En Tasks, seleccionar My roles.
- 4 En Eligible assignments, localizar el rol deseado.
- 5 Seleccionar Activate.
- 6 Realizar la verificación de seguridad adicional.
- 7 Completar la MFA y seleccionar Activate.
- 8 Opcional: especificar un Scope reducido de recursos.
- 9 Opcional: establecer una hora de inicio personalizada.
- 10 Indicar el motivo en Reason.
- 11 Seleccionar Activate.
- 12 Si el rol requiere aprobación, la solicitud queda pendiente.

Puntos clave

Delegación controlada

Autorizar partners con el rol mínimo necesario (Full o Limited) y auditar periódicamente.

Roles a través de grupos

Grupos role-assignable e inmutables, con membresía Assigned y protegida frente a la autoelevación.

Alcance acotado

Las unidades administrativas limitan la administración por división, geografía o suborganización.

Datos protegidos

Revisar el uso compartido de SharePoint y corregir el oversharing con controles y informes.

Privilegio mínimo

PIM sustituye el acceso permanente por activaciones temporales, aprobadas y auditadas.